# CRAFT Configuration and Validation

*Certificate Request Agent for Tickets | Administrator reference*

Select and order one or more Linux operating modes to fit the environment: certificate enrollment through CES and AD CS, privileged credential linking through msDS-KeyCredentialLink, or unprivileged PKINIT with a certificate exported from Windows (BYOC, Bring Your Own Cert), or Constrained Delegation with a broker keytab. This guide gives mode-specific configuration and acceptance checks. The linked installation guide contains complete Linux commands and the configuration reference.

| Requirement | Enrollment Agent | Key Trust | BYOC |
|---|---|---|---|
| Linux acquisition | Setuid launcher; craft service account | Setuid launcher; craft service account | Caller UID; mode-0755 executables |
| User credential | CA-enrolled short-lived certificate | Temporary linked public key and local identity | Transferred certificate and private-key PEM pair |
| Service keytab / LDAP | Required | Required | Unused |
| CES / agent / user template | Required | Unused | Direct Windows enrollment template; no Linux CES/agent |
| Authorization | CA agent/template/recipient restrictions | Scoped AD attribute delegation | User enrollment and KDC certificate mapping |
| KDC certificate trust / CRLs | Required | Required | Required |
| Setup | Enrollment Agent instructions | Key Trust instructions | BYOC instructions |

Constrained Delegation uses the same privileged Linux installation as Enrollment Agent and Key Trust, plus a dedicated broker AES keytab with protocol transition and approved target SPNs. It requires no certificates, CRLs, PKINIT, LDAP or CES. See the Constrained Delegation setup page.

Set modes to an ordered list, such as home enrollment or key_trust enrollment. Configure every enabled mode. Acquisition failures advance to the next mode; the first success supplies the cache. Broker modes share one account/keytab and request cooldown. Use constrained_delegation alone to prohibit a user TGT.

## Shared Linux preparation

Build as an ordinary user from the repository root with GCC/libstdc++ 13.1 or equivalent C++20 support, CMake 3.16 or newer, OpenSSL 1.1.1 or newer, MIT Kerberos, libcurl, libxml2, OpenLDAP, SASL and MIT GSSAPI. Install MIT PKINIT for certificate modes and, for Enrollment Agent and Key Trust, the SASL GSSAPI plugin. CES Negotiate needs libcurl SPNEGO. Use supported patched packages meeting the installation guide's requirements. A working /dev/log socket is required.

```
cmake -S source -B build -DCMAKE_BUILD_TYPE=Release
cmake --build build -j2
ctest --test-dir build --output-on-failure
```

Install the production launcher, worker and optional maintainer manually; there is no CMake installation target. Keep /etc/craft/config and krb5.conf root-owned mode 0644 with protected parents. Pin the realm, KDC and expected KDC hostname; provide populated kdc-trust.pem and current kdc-crls.pem for certificate modes. Enrollment Agent and BYOC also require ca-trust.pem and ca-crls.pem for the user certificate; enrollment also validates the agent. Empty placeholders are invalid. Refresh CRLs independently.

Broker modes add craft:craft, craft-users and /run/craft owned craft:craft mode 0700. Private service credentials are root:craft mode 0640. Only the service account belongs to craft; ordinary users join craft-users. Keep enabled=no and the launcher non-setuid until the selected setup is ready, then enable acquisition and set launcher mode 4750. Users invoke craft directly without sudo.

Shared installation | Privileged installation | Configuration reference

# Enrollment Agent setup

Complete Enrollment Agent setup | Enrollment flow diagram | CA authorization

Complete the shared Linux and privileged installation. Provision a directory/submission account with AES keys and install submitter.keytab. Install the enrollment-agent certificate and matching unencrypted key as agent.pem and agent.key. Install CES HTTPS trust as https-trust.pem. Protect these files as root:craft mode 0640.

Configure AD CS and CES for initial enrollment using a dedicated EOBO user template. Restrict the actual signing agent, permitted template and approved recipient group at the CA; exclude privileged identities. Resolve Linux names to the intended AD sAMAccountName and directory UPN. CA-built identity and SID mapping must satisfy current KDC policy. The CA helper performs partial lab provisioning and verifies narrow restrictions before publication/export; configure those restrictions first.

```
enabled=no
domain=domain.local
realm=DOMAIN.LOCAL
modes=enrollment
netbios=DOMAIN
service_principal=svc-linux-enroll@DOMAIN.LOCAL
template_oid=1.3.6.1.4.1.311.21.8.999.1
ces_url=https://ces.domain.local/IssuingCA_CES_Kerberos/service.svc/CES
ces_auth=negotiate
key_bits=3072
certificate_cn={user}
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
cert_remaining_max_seconds=36000
cert_total_max_seconds=36000
minimum_interval_seconds=60
```

Replace every placeholder. template_oid is the actual msPKI-Cert-Template-OID, not the template display name. The CES URL is pinned, not discovered through Windows enrollment policy. Configure the optional GC endpoint/base when needed. The helper signs DOMAIN\user in the EOBO request and validates the returned certificate against the directory UPN.

| CES transport | Additional requirements |
|---|---|
| negotiate | Service keytab authenticates HTTP as well as LDAP. Configure the HTTP SPN and required CES-to-CA constrained delegation. The worker's short-lived transport TGT is never returned to the user. |
| mtls | Use the actual certificate-authenticated CES endpoint and separate https-client.pem / https-client.key mapped to the submitting account. The directory keytab is still required. |

CES HTTPS uses https-trust.pem for chain/hostname verification. Optional https-crls.pem enforces revocation for the whole server chain; without it, HTTPS CRL/OCSP checks are absent. Refresh all required CRLs independently.

Validate the template profile on the next page and prove CA refusal for out-of-scope recipients. Set enabled=yes and enable the setuid launcher only when ready. Test as an approved user with modes=enrollment so another acquisition path does not hide the enrollment setup.

# Enrollment Agent certificate and ticket policy

The CA controls the issued certificate. CSR extensions are requests, and client-side validation cannot replace CA authorization. This profile applies to CRAFT enrollment; BYOC accepts its separate supplied-certificate profile and Key Trust is authorized by its directory key.

| Property | Required enrollment profile |
|---|---|
| Subject and identity | The UPN otherName SAN (1.3.6.1.4.1.311.20.2.3) must match the directory-resolved UPN. The CA supplies the account SID security extension for current AD certificate mapping. The CN is not the authentication identity. |
| Client EKUs | Client Authentication 1.3.6.1.5.5.7.3.2<br>Smart Card Logon 1.3.6.1.4.1.311.20.2.2<br>PKINIT Client Authentication 1.3.6.1.5.2.3.4 |
| Key and basic constraints | RSA defaults to 3072 bits; key_bits accepts 2048/3072/4096 and must meet the template minimum. Explicit CA:FALSE with no path length; digitalSignature required; keyCertSign and cRLSign forbidden. The CSR also requests keyEncipherment. |
| Template | Template-information extension must contain the configured template OID. The signing agent must be authorized for that template and recipient. |
| Validity | Current validity with more than 60 seconds remaining. Default cap is ten hours total notBefore-to-notAfter, including backdating, and ten hours remaining. The client refuses excessive validity rather than changing dates. |
| Trust and revocation | Matching private key, configured CA chain and current CRLs for the user certificate and enrollment agent. KDC certificate trust and revocation are checked separately. |
| Agent profile | Certificate Request Agent EKU 1.3.6.1.4.1.311.20.2.1, matching private key, trusted chain and current CRLs. Scope comes from CA restrictions, not that EKU. |

### Shared ticket policy

tgt_seconds=36000 and renew_seconds=604800 request ten-hour initial validity and seven-day renewal in certificate modes. Set renew_seconds to 0 to disable renewal; otherwise it must exceed tgt_seconds. The KDC decides the actual grant, including certificate/key-lifetime constraints. Strict require_full_tgt_lifetime=yes rejects shortened grants and preserves the cache; no accepts them with a warning. CRAFT never rewrites issued ticket times. AES256/AES128 are required for both session keys and outer ticket encryption.

### Generated common name

certificate_cn={user} controls the Enrollment Agent CSR CN and Key Trust local-certificate CN. Tokens are {user}, directory-resolved {upn} and {domain}; the result must be 1-64 printable ASCII characters. A CA-built subject can override the CSR. The setting does not alter BYOC's supplied certificate or the requested principal. Preserve UPN/SID binding and recipient restrictions when configuring CA subject policy.

Windows enrollment preparation | Configuration example

# Key Trust setup

Complete Key Trust setup | Credential-linking diagram | Directory delegation

Complete shared Linux and privileged installation. Provision the service principal with AES keys and install submitter.keytab as root:craft mode 0640. Use a schema exposing msDS-KeyCredentialLink and a writable KDC supporting NGC/Key Trust, as provided by Windows Server 2016 or later. A domain-functional-level label alone does not establish these capabilities. The KDC still needs a trusted PKINIT certificate and current CRLs.

Pin the same writable DC in krb5.conf and kt_dc_url so its KDC sees the new key immediately. The LDAP SASL/GSSAPI bind must provide integrity and encryption at SASL SSF 128 or higher. For Key Trust alone, remove the optional pkinit_pool reference to user-certificate ca-trust.pem if unnecessary, or point it at a root-controlled bundle of KDC intermediates; retain KDC anchors and CRL checking.

```
enabled=no
domain=domain.local
realm=DOMAIN.LOCAL
modes=key_trust
service_principal=svc-linux-enroll@DOMAIN.LOCAL
kt_dc_url=ldap://dc01.domain.local
key_bits=3072
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
minimum_interval_seconds=60
```

Delegate ReadProperty/WriteProperty on only msDS-KeyCredentialLink over a reviewed OU of ordinary users or a single user. The service account can authenticate as every target in that scope. Keep privileged identities out, protect the OU membership/ACL administrators, and prevent the service account from rewriting its delegation. Preview the helper rule before applying it:

```
.\scripts\Grant-CRAFTKeyCredentialLink.ps1 -ServiceAccount svc-linux-enroll `
    -TargetOU "OU=CRAFT Users,DC=domain,DC=local" -WhatIf
```

CRAFT generates a fresh RSA key and locally issued certificate. The linked key authorizes PKINIT without user-certificate CA enrollment, CES, an agent or a template. MIT Kerberos handles freshness tokens; validate against the actual KDC policy. Review the temporary issuer trust scope in the linked security guide.

An independent process adds and removes CRAFT's exact value while preserving existing keys. Successful acquisition requires removal before cache publication. Cleanup also runs after acquisition failure or worker termination and retries uncertain directory outcomes. A continuing directory outage or host failure can leave a usable key. Failed cleanup blocks publication and reports a CRITICAL AUTHPRIV event identifying the object and worker when cleanup can run; inspect and remove only confirmed residual values, retaining legitimate keys.

Review delegation and trust, set enabled=yes, and enable the setuid launcher. Test with modes=key_trust. Verify the returned caller principal, attribute cleanup, existing-key preservation and directory refusal for out-of-scope accounts; repeat after revoking the delegation.

Temporary issuer trust

# BYOC setup

Complete BYOC setup | Windows export flow diagram | Windows helper details

Complete shared Linux installation with ordinary mode-0755 executables. No setuid bit, service account, caller group, service keytab, LDAP lookup, CES or /run/craft is needed for Linux acquisition. Host installation and public Kerberos/trust provisioning remain administrator tasks.

On Windows, run the helper as the intended signed-in domain user without elevation. Choose the template's internal name or OID, with direct user enrollment, exportable software keys and a KDC-accepted identity/profile. Windows PowerShell and its PKI module use AD enrollment policy to select an eligible CA. No OpenSSL or enrollment-agent credential is required.

```
.\scripts\Request-CRAFT-Certificate.cmd UserLogon "C:\Users\Alice\CRAFT Certificate"
```

Securely transfer both exported user.pem and matching unencrypted PKCS#8 user.key to Linux after the helper returns successfully. Keep its private tracking metadata on Windows. As the intended Linux user, install the pair in the NSS-resolved home; HOME and XDG overrides do not change that location:

```
mkdir -p ~/.config/craft
chmod 0700 ~/.config/craft
install -m 0600 /path/to/transferred/user.pem ~/.config/craft/user.pem
install -m 0600 /path/to/transferred/user.key ~/.config/craft/user.key
```

Both files must be caller-owned regular files, nonempty, at most 1 MiB and have one hard link. Symlinks are refused. The key must be unencrypted with no group/other permissions; the certificate must not be group/world-writable. The home, .config and craft directories must be caller-owned and not group/world-writable. Direct PFX loading, passphrase prompts, PKCS#11 and hardware-key backends are unsupported.

```
enabled=no
modes=home
domain=domain.local
realm=DOMAIN.LOCAL
tgt_seconds=36000
renew_seconds=604800
require_full_tgt_lifetime=yes
```

Provide root-owned mode-0644 CA and KDC trust bundles with current CRLs. The user certificate must match the key, be non-CA, and have digitalSignature without certificate/CRL signing, Smart Card Logon or PKINIT Client Authentication EKU, exactly one UPN SAN, and more than 60 seconds of current validity. basicConstraints may be absent; if present, require CA:FALSE without a path length. The KDC must map it to <Linux username>@<realm>. CRAFT does not query the directory UPN or pin the enrollment template/ten-hour certificate cap in this mode.

Set enabled=yes when ready. modes=home requires the supplied pair. Add other modes only when their fallback authority is intended and provisioned. Repeat the Windows helper to check renewal and transfer replacements before expiry. Its default window is one calendar month; /RenewBeforeDays changes it, and /DeleteAfterExport optionally removes the Windows-store certificate. Neither the helper nor CRAFT schedules or transfers replacements automatically.

# Constrained Delegation setup

Complete Constrained Delegation setup | Broker AD policy | Delegation flow

Use a dedicated ordinary broker account, unique SPN and AES keytab. Enable protocol transition and account-based constrained delegation to only the required services. TrustedForDelegation must remain false. Install submitter.keytab as root:craft mode 0640, and pin the realm/KDC and AES policy in root-controlled krb5.conf. No CA or LDAP setup is needed.

```
enabled=no
domain=domain.local
realm=DOMAIN.LOCAL
modes=constrained_delegation
service_principal=CRAFT/broker.domain.local@DOMAIN.LOCAL
service_spns=cifs/files.domain.local@DOMAIN.LOCAL HTTP/portal.domain.local@DOMAIN.LOCAL
service_ticket_seconds=36000
minimum_interval_seconds=60
```

service_spns accepts 1-32 same-realm service/host@REALM names separated by spaces. Match application names including case. Wildcards, krbtgt, the broker principal and cross-realm targets are refused. Every target must also be authorized in the broker account msDS-AllowedToDelegateTo list. One denied target fails the entire acquisition and preserves the previous cache. Home certificates are ignored.

service_ticket_seconds defaults to 36000 and accepts 60-604800 seconds. The KDC may shorten grants; CRAFT accepts shorter valid AES tickets. TGT lifetime and renewal settings do not apply. Final tickets may be forwardable/forwarded, but no TGT, broker credential, S4U2Self evidence or proxy metadata is published.

The AD policy limits services, not recipient users. Restrict local callers through craft-users and protect Linux name assignment. Protect sensitive AD users against delegation. Services sharing one AD account/key are not isolated by different SPN labels. Use separate target identities where service isolation matters.

Stop existing maintainers and remove the old TGT cache before switching to Constrained Delegation. After enabling acquisition, verify every cache record, service authentication with a client that accepts a service-only cache, unapproved-target and nondelegable-user denial, disabled home mode and cache preservation. Existing credentials are not revoked by configuration changes.

craft-maintain refreshes the complete service batch before its earliest expiry, through the broker rather than TGT renewal. Keep the acquisition interval below the actual refresh interval. Status reports ticket_kind=service, earliest ticket_expires and renew_until=0. Test refresh, outages and watched-job exit with short service lifetimes.

# Acceptance checks and ongoing operation

Run the offline checks, then validate the chosen installed mode against disposable identities in an isolated AD lab. Offline fixtures or a successful MIT KDC trial do not establish AD certificate mapping, CES interoperability, the directory delegation or the installed setuid boundary.

| Scope | Required observations |
|---|---|
| Every mode | Run as the intended non-root user without sudo. Confirm Linux-name principal, caller-owned mode-0600 cache, mode-appropriate flags and lifetimes, AES session/ticket encryption and actual lifetimes. Test a real Kerberos-enabled service. |
| Selection and failure | Verify configured order, fallback after acquisition errors and refusal of disabled modes. A service-only list must never produce a TGT. All-mode failure must preserve the cache. Test wrong mapping, stale required CRLs, key mismatch, KDC outage, RC4 and shortened strict-mode grants. |
| Enrollment Agent | Inspect UPN, CA SID mapping, template, three EKUs, matching key, CN behavior, chain/CRLs and total validity. Prove CA denial for unauthorized agents/templates/recipients and correlate CA/CES audit identity. |
| Key Trust | Prove scoped attribute rights and denial outside the scope. Inspect the added/removed value and existing keys before and after success, failed PKINIT and interruption. Force cleanup failure, verify refusal to publish and remove the residual key. Test revocation of delegation and KDC freshness interoperability. |
| BYOC | Verify ordinary Linux execution without service credentials or runtime directory, safe Windows PEM export/transfer, KDC mapping, certificate replacement and inherited no_new_privs. Wrong-account and unsafe/partial pairs must preserve the cache. |

```
cache=$(/usr/local/bin/craft) || exit "$?"
export KRB5CCNAME="$cache"
klist -ef -c "$KRB5CCNAME"
```

### Long running jobs

```
job_pid=$$
cache=$(/usr/local/bin/craft-maintain --watch-pid "$job_pid") || exit "$?"
export KRB5CCNAME="$cache"
```

The ordinary maintainer needs Linux with /proc and system /etc/krb5.conf matching the pinned realm/KDC and AES policy. It monitors the job through a pidfd when available, or /proc on older kernels such as RHEL 8. The scheduler must retain detached processes. Renewal uses the cache alone; fresh authentication applies the same configured mode selection. Keep CRLs, service credentials and supplied certificates current. Acquisition and renewal failures are retried. A status-file write failure stops the maintainer; failures do not terminate the watched job.

Test renewal, fresh authentication near the absolute renewal deadline, outages, concurrent jobs and termination with the watched PID under the actual scheduler. Applications must reload refreshed credentials. Cache files remain after exit, and certificate expiry or directory-key removal does not revoke already-issued tickets.

Full acceptance cases | Maintenance setup and status

## Audit maintenance and operational disable

Read AUTHPRIV records from the host logging service with administrator access. Workers in one invocation share an opaque request= identifier. Correlate launcher and worker processes through host audit metadata. Key Trust records identify the object and worker; correlate them with directory change event 5136 and KDC event 4768. Configure the required directory SACL and CA audit categories. Do not place private keys, tickets or export passwords in logs.

```
sudo journalctl -t craft -t craft-worker -t craft-maintain
```

Every mode requires /dev/log. Failure to submit an audit record blocks startup, credential release or renewal publication. The final launcher completion record follows cache replacement, so a logging failure there can be reported after the cache changed. Detached maintenance can retry after an audit failure; failure and exit diagnostics are best effort. Local submission does not establish durable retention or forwarding. Install the example host audit rules only after adjusting paths, architecture and rules for files actually present.

For failures, inspect the log identity/PID named in the caller notice. Check clocks, PKINIT/SASL plugins, principal and SPNs, mapping, current CRLs, certificate profiles and effective CA/directory authorization. Diagnose a rejection without weakening TLS verification, required CRLs or mapping policy.

| Operation | Administrator action |
| --- | --- |
| Keep authentication available | Refresh CA/KDC and optional CES CRLs before next-update; rotate service credentials; replace and securely transfer supplied certificates before expiry. |
| Stop fresh acquisition | Set enabled=no or remove launcher execute access. Removing only setuid stops broker modes; a supplied pair remains usable only if home is enabled. |
| Stop ticket renewal | Inspect job status and send SIGTERM to each recorded maintainer_pid. Acquisition disable alone does not stop cache-only renewal. Cache files remain. |
| Withdraw authentication authority | Revoke the CA agent/recipient authorization or AD delegation, rotate compromised credentials and remove confirmed residual Key Trust values. Review issued certificates, tickets and service sessions through incident response. |

Assign owners for credential/CRL lifecycle, recipient/delegation review and logs. Repeat acceptance after policy or credential changes. Certificate/key removal, cache deletion and maintenance stop do not revoke already-issued tickets.

Constrained Delegation refreshes all service tickets through the broker before the earliest expiry. It has no cache-only renewal and needs the broker and KDC for each refresh. Status identifies ticket_kind and ticket_expires. Removing broker delegation blocks fresh acquisition but does not revoke already-issued tickets.

Audit and troubleshooting | Host audit rules | Operational disable

Source code, scripts, configuration examples and documentation are licensed under GNU GPL version 3 only (GPL-3.0-only). See LICENSE for the terms and warranty disclaimer.